

Phishing Email Detection & Awareness

Internship program: Future Intern – Cybersecurity

Task: Task 2

Prepared by: Remi Eli Kokou AKAKPO

Role: Cybersecurity intern

Date: 15/03/2026

This report presents the results of a forensic analysis of phishing emails collected from the public repository phishing_pot (GitHub). The goal is to identify the technical and behavioral indicators characteristic of phishing attacks, assess their risk level, and provide concrete recommendations for IT teams and end users.

Four (4) malicious emails were analyzed, covering various attack typologies: financial brand impersonation (cryptocurrency), compromised infrastructure, commercial identity theft, and emotional manipulation (romance scam). The analysis was conducted using the MXToolbox Email Header Analyzer and Google Admin Toolbox tools.

Indicator	Value	Status
Emails analyzed	4 samples	Complete
Emails classified PHISHING	4 / 4 (100%)	Critical
Tools used	MXToolbox, G-Admin Toolbox	Validated
Blacklisted IPs detected	2 (Hops 3 & 6 - Circlepix)	Alert

2. Context and Methodology

2.1 Mission Context

Phishing represents the most widespread cyber threat in professional environments. According to industry data, more than 90% of cyberattacks begin with a malicious email. The ability to identify, analyze, and classify these threats is a fundamental skill for any SOC analyst or GRC specialist.

2.2 Sample Sources

The analyzed emails come from the public repository phishing_pot (GitHub — rf-peixoto), used exclusively for learning and research purposes. No active interaction with malicious links or servers was performed.

2.3 Analysis Tools Used

Tool	Function	URL
MXToolbox Header Analyzer	SMTP header analysis, SPF/DKIM/DMARC verification, blacklist detection	mxtoolbox.com
Google Admin Toolbox	Routing path visualization, delivery delay, SMTP relay	toolbox.googleapps.com
AbuseIPDB (reference)	Verification of IP addresses against known threat databases	abuseipdb.com

2.4 Analysis Methodology

For each email, the following approach was applied systematically:

- Extraction of raw SMTP headers from the source sample
- Submission to the analysis tool for routing path decoding
- Verification of authentication mechanisms: SPF, DKIM, DMARC
- Identification of anomalies: sender domain, source IP, delays, blacklists
- Semantic analysis of content (subject, message body, manipulation techniques)
- Risk level classification according to the grid defined below

2.5 Risk Classification Grid

Level	Criteria	Recommended Action
PHISHING	Confirmed identity theft, multiple indicators, authentication failure	Immediate blocking, SOC reporting, user awareness
SUSPICIOUS	Partial anomalies, questionable authenticity, atypical link or sender	Quarantine, in-depth analysis, manual verification
SAFE	Complete authentication, verified domain, consistent content	No action required

3. Detailed Email Analysis

3.1 Email 1 - Cryptocurrency Brand Impersonation (RippleNet/XRP)

Field	Value
Message-ID	LKqWCR6TUkOch9sF07ab0mfooZEFRCMnUTUi7q40@WIN-R4BNMS0KP2
Date	04/09/2023 13:53:07 UTC - Delivered in 2 seconds
Sender	RippleNet <clients@beliterary.com> - via PHPMailer 6.1.7
Subject	Discover The Power Of XRP Staking
SPF	PASS (IP Unknown)
DKIM	PASS (domain Unknown)
DMARC	BESTGUESSPASS (non-strict policy)

Phishing Indicators Identified

- Critical domain mismatch: RippleNet is supposed to send from @ripple.com, never from @beliterary.com (a literary website unrelated to crypto)
- PHPMailer 6.1.7: open-source mass mailing tool, never used by companies of Ripple's stature
- Source IP 185.174.101.55: dansonsolutions.org server, no connection to official Ripple infrastructure
- SPF/DKIM pass on a wrong domain: authentication checks validate the beliterary.com domain, not RippleNet - automatic filters may be fooled
- Financial bait: subject focused on XRP staking to incentivize clicking and providing financial information

Risk Summary	Classification
Confirmed impersonation of the RippleNet brand via an unrelated third-party domain. Despite passing SPF/DKIM checks, the attack vector is clearly identified.	PHISHING

3.2 Email 2 - Compromised Infrastructure (Circlepix)

This email presents the most technically sophisticated profile, using a compromised third-party infrastructure and two blacklisted IPs detected in the routing chain.

Analysis Capture - Header Routing (MXToolbox)

Relay (Seconds)						
0 0.5 1 1.5 2 2.5 3 3.5						
Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	unknown 127.0.0.1	geopod-smtpd-4	ESMTP	9/11/2023 9:23:53 AM	✓
2	*		filterdrecv-6bbccbc8c-tnmhm	SMTP	[]	
3	2 seconds	o6.sgmail.circlepix.com 198.37.147.85	AM6EUR05FT023.mail.protection.outlook.com 10.233.241.96	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/11/2023 9:23:55 AM	✗
4	1 Second	AM6EUR05FT023.eop-eur05.prod.protection.outlook.com 2603:10a6:20b:e0:cafe::cd	AM6PR01CA0038.outlook.office365.com 2603:10a6:20b:e0::15	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/11/2023 9:23:56 AM	✓
5	1 Second	AM6PR01CA0038.eurprd01.prod.exchangelabs.com 2603:10a6:20b:e0::15	LV2PR19MB5863.namprd19.prod.outlook.com 2603:10b6:408:173:21	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/11/2023 9:23:57 AM	✓
6	2 seconds	LV2PR19MB5863.namprd19.prod.outlook.com ::1	MN0PR19MB6312.namprd19.prod.outlook.com	HTTPS	9/11/2023 9:23:59 AM	✗

Gmail & Yahoo are now requiring DMARC - Get yours setup with Delivery Center

SPF and DKIM Information

Figure 1 - SMTP routing path analysis (MXToolbox) - Circlepix Email

Phishing Indicators Identified

- Hop 1 - Hidden origin: From unknown 127.0.0.1 - the real sender concealed behind localhost
- Hop 2 - Empty From field: intentional anonymization of the intermediate relay
- Hop 3 - Blacklisted IP: o6.sgmail.circlepix.com (198.37.147.85) - compromised real estate server, flagged as malicious
- Hop 6 - Second blacklist: LV2PR19MB5863 via HTTPS - unusual protocol for an internal mail relay
- Advanced technique: use of a legitimate compromised server to bypass reputation filters

Risk Summary	Classification
Sophisticated attack using a compromised third-party server (circlepix.com). Two blacklisted IPs detected. Real origin hidden behind 127.0.0.1.	PHISHING

3.3 Email 3 - Triple Authentication Failure (123Milhas)

MessageId	20230815024443.676EF41794@ekpfr728-abhiy-ekpfr728
Created at:	15/08/2023 2:44:43 UTC (Delivered after 24 hours)
From:	123Milhas <desconto123milhas@hotmail.com>
To:	phishing@pot
Subject:	Todas as passagens aereas com ate 50% de desconto!
SPF:	temperror avec l'adresse IP Unknown! En savoir plus
DKIM:	none En savoir plus
DMARC:	fail En savoir plus

#	Delay	From *	To *	Protocol	Time received
0	24 hours	VE1EUR01FT102.eop-EUR01.prod.protection.outlook.com	→ FR3P281CA0191.outlook.office365.com		16/08/2023 3:02:50 UTC

Figure 2 - SPF Temperror + DKIM None + DMARC Fail — 123Milhas Email

Field	Value
Message-ID	20230815024443.676EF41794@ekpfr728-abhiy-ekpfr728
Date	15/08/2023 2:44 UTC - Delivered after 24 HOURS (shown in red)
Sender	123Milhas <desconto123milhas@hotmail.com>
SPF	TEMPERROR - IP Unknown (intentional DNS error)
DKIM	NONE - No cryptographic signature
DMARC	FAIL - Complete authentication policy failure

Phishing Indicators Identified

- 24-hour delay: critical indicator shown in red - sign of a blacklisted server or attempt to bypass temporal filters
- Obvious identity theft: 123Milhas is a real Brazilian airline, but its official email is @123milhas.com.br - never @hotmail.com
- Triple authentication failure: SPF Temperror + DKIM None + DMARC Fail - no verification mechanism is satisfied
- Promotional offer bait: 'All airline seats with up to 50% discount' - classic social engineering technique

Risk Summary	Classification
Most technically detectable case: triple SPF/DKIM/DMARC failure. Abnormal 24h delay. @hotmail.com sender for an airline. Obvious classification.	PHISHING

3.4 Email 4 - Romance Scam (Meet Ukrainian Women)

MessageId	YDBH48AMTO.1c69fb81.7aec0.5503SMTPIN_ADDED_r02of@VLCHNECLuLm4p.EURPRD10.PROD.OUTLOOK.COM
Created at:	26/09/2023 8:17:44 UTC (Delivered after 4 sec)
From:	Meet Ukrainian Women <palm@starh.cloud>
To:	<phishing@pot>
Subject:	Enjoy Your Safe Date!
SPF:	pass avec l'adresse IP Unknown! En savoir plus
DKIM:	fail avec le domaine Unknown! En savoir plus
DMARC:	bestguesspass En savoir plus

#	Delay	From *	To *	Protocol	Time received
0	3 sec	NAM10-BN7-obe.outbound.protection.outlook.com	→ AM7EUR06FT055.mail.protection.outlook.com		26/09/2023 8:17:47 UTC

Figure 3 - SPF Pass + DKIM Fail + DMARC Bestguesspass - Romance Scam

Field	Value
Message-ID	YDBH48AMTO.1c69fb81.7aec0.5503SMTPIN_ADDED_r02of@VLCHNECL...
Date	26/09/2023 8:17:44 UTC - Delivered in 4 seconds
Sender	Meet Ukrainian Women <palm@starh.cloud>
Subject	Enjoy Your Safe Date!
SPF	PASS (IP Unknown)
DKIM	FAIL - Domain Unknown
DMARC	BESTGUESSPASS - Non-strict policy

Phishing Indicators Identified

- Generic .cloud domain with no verifiable corporate identity (starh.cloud)
- SPF Pass + DKIM Fail: revealing combination - legitimately registered domain but unauthenticated content, potentially modified after sending
- Microsoft infrastructure used as relay (NAM10-BN7-obe.outbound.protection.outlook.com): technique of creating a free Outlook account to benefit from Microsoft's reputation
- Romance Scam: unlike classic financial phishing, this category aims to establish an emotional relationship to extract money over the long term - potentially more damaging
- SMTPIN_ADDED tag in MessageID: added by Outlook filters during message inspection, indicating the mail was flagged

Risk Summary	Classification
Romance scam using a generic .cloud domain and Microsoft infrastructure as a vector. DKIM failure. Category of fraud with high psychological and financial impact.	PHISHING

4. How These Attacks Work

4.1 The Phishing Attack Cycle

Phishing attacks follow a five-step cycle that every user must know to protect themselves:

Step	Phase	Description
1	Reconnaissance	The attacker identifies the target (company, brand to impersonate, email list)
2	Preparation	Creation or compromise of a domain, configuration of sending tools (PHPMailer)
3	Sending	Email distribution with social engineering techniques (urgency, fear, bait)
4	Exploitation	The user clicks the link, provides credentials, or downloads a malicious file
5	Exfiltration	Data recovery, system access, or start of a fraudulent relationship (romance scam)

4.2 Social Engineering Techniques Identified

- Artificial urgency: Your account will be suspended in 24 hours' - creates psychological pressure that short-circuits rational judgment
- Trusted brand impersonation: use of logos, names, and terminology of legitimate brands (RippleNet, 123Milhas) to induce trust
- Financial bait: discount offers, crypto gains, passive income - exploit greed or financial need
- Emotional connection (romance scam): long-term technique that builds a relationship before financial requests - major psychological impact
- Technical legitimization: routing through reputable infrastructure (Microsoft Outlook) to bypass automatic filters

5. Recommendations

5.1 For End Users - Anti-Phishing Checklist

#	DO's	DON'Ts
1	Check the sender's full email address (not just the displayed name)	Never click on a link in an urgent email without prior verification
2	Hover over links before clicking to check the actual destination URL	Never provide passwords, OTPs, or banking details via an email link
3	Contact the alleged sender through an official channel if in doubt	Never download unexpected attachments (.exe, .zip, .docm)
4	Report any suspicious email to the IT/SOC team immediately	Never reply to a phishing email even to 'unsubscribe'

#	DO's	DON'Ts
5	Be wary of any email creating urgency or offering an overly advantageous deal	Never share suspicious emails with colleagues without reporting them first

5.2 For IT & SOC Teams

- Configure strict DMARC policies (p=reject) on all organization domains to prevent impersonation
- Enable DKIM on all outbound mail servers and regularly verify key validity
- Implement a phishing reporting tool integrated into the email client (Report as Phishing button)
- Conduct regular simulated phishing campaigns to measure user maturity and adapt training
- Maintain a blacklist of domains and IPs identified as malicious (e.g., AbuseIPDB) and integrate it into the email gateway
- Train teams to recognize the SPF pass + impersonated domain combination, which can fool automatic filters

5.3 Key Indicators to Monitor (IOC - Indicators of Compromise)

IOC	Description	Criticality
DMARC: Fail	Authentication completely failed	Critical
Blacklisted IP	Source IP address flagged in threat databases	Critical
Delay > 1 hour	Abnormally high delivery delay	Critical
127.0.0.1 as source	Localhost IP masking real origin	Critical
PHPMailer / mass sending	Unprofessional mass sending tool	High
Domain ≠ displayed brand	Mismatch between displayed name and real domain	High
DKIM: None	Absence of cryptographic signature	High
Generic .cloud / .info / .xyz domain	Generic TLDs often used by malicious actors	Moderate

6. Conclusion

This analysis of four real phishing emails demonstrates the diversity and increasing sophistication of techniques used by malicious actors. Several major lessons emerge from this study:

- Automatic authentication checks (SPF, DKIM, DMARC) are necessary but insufficient: emails 1 and 4 pass SPF verifications despite their malicious nature, illustrating the limits of purely technical detection.
- The diversity of attack vectors (crypto, compromised infrastructure, commercial bait, romance scam) requires versatile user training, not just awareness of classic banking phishing.

- Legitimate infrastructures (Microsoft Outlook, real estate servers) are regularly hijacked to bypass reputation filters - the reputation of a relay domain does not guarantee the legitimacy of the message.
- The combination of technical and behavioral indicators is the most reliable method: no single indicator is sufficient to confirm phishing. It is their accumulation that allows classification.